

SOM CHANDRA

somchandra.infosec@gmail.com | +91 9507988170 | github.com/somchandra17
linkedin.com/in/somchandra17 | tryhackme.com/p/somchandra17 | somm.tf

Summary

- 156 internal findings, FY2025–26 (42 Critical/Blocker, 57 High, 57 Medium) across 10 web, API, and Android cycles, CVSS-to-SLA mapping
 - Built three in-house tools now in team use: a 9-phase Android DAST framework (~90% less time per app), GQLSweep (170+ GraphQL checks), and a Burp extension for a proprietary mobile protocol
 - Certified CompTIA Security+ (SY0-701) and eWPTXv2; top 1% on TryHackMe; 20+ NCIIPC India responsible-disclosure acknowledgments
-

Technical Skills

- **Application & API Security:** gray-box web/API VAPT, OWASP Top 10, GraphQL security, CVSS scoring and SLA mapping
 - **Mobile Offensive Security:** Android/iOS SAST/DAST, OWASP MASTG/MASVS, Frida/objectection, SSL pinning, root/jailbreak detection
 - **Security Automation:** Burp extension development (Montoya API/Java, Extender API/Jython), Python, Kotlin, FastAPI, VAPT-to-Jira
 - **Attack Surface:** subfinder, amass, httpx, and testssl.sh; CVE checks before public templates; Nessus
 - **Incident response:** credential-exposure response, secrets inventory, and read-only rotation checks
-

Experience

MoveInSync

Jun 2025 – Present

Cyber Security Engineer

Bengaluru, India

- Reported 156 FY2025–26 VAPT findings across 10 internal cycles on web, API, and Android, including an unauthenticated API, IDOR in billing reports, and a WebSocket leaking live cab location; drove CVSS-to-SLA remediation with engineering; 180 tickets reported, 100+ assigned, about 93% of assigned tickets closed
- Built a 9-phase Android DAST framework (adb, drozer, apktool) that cut per-app assessment from 1–2 days to under 1 hour (about 90%), and that work contributed to the team declining a paid PortSwigger Burp DAST purchase
- Built **GQLSweep**, a Burp extension running 170+ automated GraphQL checks across 12 categories from one right-click, surfacing alias-abuse DoS and excessive data exposure later confirmed by an external vendor
- Owned external VAPT across four vendors and four major cycles (web, Android, iOS, Driver App): false-positive filtering, compensating controls the vendor accepted, revalidation, and on-time reports for enterprise audits
- Built a Java Burp extension that decodes and re-encodes the Driver App zlib-compressed integer-array protocol, unlocking active testing of that traffic; later ported the extension to the Montoya API
- Showed an Android SSL-pinning bypass needed a rooted, instrumented device and did not reproduce on the production build
- Ran the first in-house AI/LLM assessment of an internal chatbot; prompt injection bypassed tool-persona and policy controls, and that work became a reusable method for later assessments
- Drove credential-exposure response across 3,264 secret records; a June 2026 read-only re-check found all 41 Slack webhooks and bot tokens still live after a claimed rotation, and a history rewrite dropped 13,784 records in 201 files from the pushed branches
- Migrated **Nessus** from Azure Windows to hardened AWS Linux and automated weekly Advanced scans (Sunday IST), with reports uploaded to Google Drive; built **ExternalVAPT2JIRA** (PDF/HTML findings to Jira Stories and Bugs) and **vapt-revalidator** (FastAPI IDOR/BAC retests through Burp), and neither tool writes to Jira without human approval
- Manually validated Apache Tomcat CVE-2025-66614 (client-certificate verification bypass) and CVE-2026-24734 (OCSP revocation bypass) on UAT before public nuclei templates existed, and shared the results as a team reference

MoveInSync

Jan 2025 – May 2025

Application Security Intern

Bengaluru, India

- Raised critical reflected XSS findings on the transport-management API in an internal Apr–May 2025 manual and automated VAPT, and published the report
- Escalated critical issues to engineering leads the same day during a May 2025 production-clone assessment
- Surfaced a gap on an Employee Experience employee-data call during a May 2025 authentication retrofit; engineering wrapped the call in authentication

Securaeon Initiative	Feb 2022 – Jul 2022
<i>Cyber Security R&D Intern</i>	Remote / Kolkata
Created security walkthroughs, proof-of-concept material, and practical lab content for upcoming cybersecurity products and courses	
Bugcrowd	Oct 2021 – Dec 2021
<i>Security Researcher (freelance)</i>	Remote
Reported web vulnerabilities through open bug bounty programs, and wrote impact, proof of concept, and remediation context for program security teams	

Projects

TrashDroid	Mar 2026 – Jul 2026
Somchandra17/TrashDroid - Built the public counterpart of the internal Android DAST framework: nine Python phases orchestrating adb, drozer, apktool, and sqlite3 - Covered exported-component SQLi and path traversal, SQLite deep-dumps, logcat, heap and /proc maps, ADB backup, manifest review, post-logout re-launch and intent extras, and PII and secret detection - Added Frida 17 bypasses for SSL pinning, root detection, and debugger detection, plus an AI-review triage package	
TrashiOS	Jun 2026
Somchandra17/TrashiOS - Built the public counterpart of the internal iOS framework: 13-phase SAST and DAST on a USB-connected jailbroken device via libimobiledevice, SSH-over-USB, and Frida/objection - Mapped checks to OWASP MASTG and MASVS, from Info.plist and Mach-O through keychain protection class, URL schemes, backup, and pinning and jailbreak, and triaged the AI-ready package from an ETS UAT iOS build	
Burp AI Agent	Apr 2026
six2dez/burp-ai-agent Merged an NVIDIA NIM backend and a reworked OpenAI-compatible backend (with HTTP 429 handling) into six2dez/burp-ai-agent, with registry, settings, and config-panel wiring (Kotlin, PR 44)	
TrashRecon	Mar 2026 – Jun 2026
Somchandra17/TrashRecon Dockerized recon across 17 tools and 10 phases, with resume support and structured JSON so finished tool outputs are skipped on rerun	

Certifications

- eWPTXv2 – eLearnSecurity Web Application Penetration Tester eXtreme, Jan 2023
- CompTIA Security+ (SY0-701), Dec 2024

Achievements

- Hall of Fame disclosures:** Mastercard Inc. SSTI escalated to LFI (P1); Rakuten session fixation (P2); Chaturbate Inc. stored XSS (P2)
- 20+ NCIIPC India responsible-disclosure acknowledgments:** client-side authentication bypass, missing rate limits, XSS, SQL injection, and account takeover
- Top 1%** on TryHackMe
- CTF:** 5th place, OWASPLPU CTF 2022; 9th place, WTFCTF 2022; 34th place, RuCTF 2022

Education

B.Tech in Computer Science and Engineering (Hons.)	Jun 2021 – May 2025
Lovely Professional University, Jalandhar, Punjab Specialization: Cybersecurity and Blockchain	